RAPPORT DE PROJET

Audit de Sécurité Réseau d'Entreprise

Projet ASRdE

GROUPE DE RÉALISATION

Groupe de Réalisation : Équipe Sécurité IT

ENCADREUR

Encadreur : Pr. Rachid Dakir

INSTITUTION

FACULTÉ POLYDISCIPLINAIRE DE OUARZAZATE

MATIÈRE

CYBERSÉCURITÉ S4

AUTEURS

MOHAMED AIT BELLA & BILAL SIKI

VERSION

1.0

DATE

Avril 2026

Table des Matières

1. Contexte général et cadrage de l'audit 3

1.1 Introduction

1.2 Contexte de la cybersécurité en entreprise

1.3 Objectifs d'un audit de sécurité réseau

1.4 Présentation de l'entreprise (ASRdE)

1.5 Périmètre de l'audit

1.6 Problématique

1.7 Analyse des risques initiaux

1.8 Objectifs du projet

1.9 Contraintes

1.10 Méthodologie

2. Étude des normes et outils d'audit 8

2.1 Introduction

2.2 Normes et référentiels

2.3 Types d'audit

2.4 Techniques d'audit

2.5 Outils d'audit

2.6 Métriques CVSS

3. Méthodologie d'audit et collecte des données 12

3.1 Introduction

3.2 Phase de préparation

3.3 Phase de reconnaissance

3.4 Scan réseau

3.5 Analyse des vulnérabilités

3.6 Tests d'intrusion

3.7 Analyse du trafic

4. Analyse des résultats et identification des failles 16

4.1 Introduction

4.2 Cartographie du réseau

4.3 Identification des vulnérabilités

4.4 Analyse des risques

4.5 Exemples de failles détaillées

4.6 Tableaux de priorisation

5. Recommandations et plan d'amélioration 22

5.1 Introduction

5.2 Plan de remédiation

5.3 Renforcement de la sécurité

5.4 Politique de sécurité

5.5 Segmentation VLAN

5.6 Déploiement MFA

5.7 Plan d'action priorisé

6. Conclusion générale et perspectives 28

6.1 Bilan global

6.2 Résultats de l'audit

6.3 Apports du projet

6.4 Perspectives

Annexes et Bibliographie 32

Chapitre 1 : Contexte général et cadrage de l'audit

1.1 Introduction

La sécurité de l'information est devenue un pilier stratégique fondamental pour toute organisation moderne. Dans un monde de plus en plus interconnecté, les cybermenaces évoluent constamment en sophistication et en fréquence. Face à cette réalité, une posture réactive ne suffit plus : les organisations doivent adopter une approche proactive qui anticipe les menaces potentielles.

Ce projet d'audit de sécurité a été élaboré dans le cadre du cours de Cybersécurité S4 à la Faculté Polydisciplinaire de Ouarzazate. Notre approche simule une démarche proactive pour évaluer et renforcer les défenses d'une infrastructure d'entreprise type, en adoptant le point de vue d'un attaquant (hacker éthique).

1.2 Contexte de la cybersécurité en entreprise

Les statistiques récentes montrent une augmentation significative des cyberattaques ciblant les infrastructures d'entreprise :

- Augmentation de **67%** des attaques par ransomware en 2025
- Coût moyen d'une violation de données : **4.45 millions USD**
- **85%** des violations impliquent des facteurs humains
- Temps moyen de détection d'une intrusion : **207 jours**

> **Principe fondamental :** La triade CIA (Confidentialité, Intégrité, Disponibilité) doit être respectée. Les solutions de sécurité doivent être transparentes et faciles à adopter pour les utilisateurs non techniques.

1.3 Objectifs d'un audit de sécurité réseau

L'objectif principal d'un audit de sécurité réseau est d'identifier les faiblesses d'une infrastructure avant qu'elles ne soient exploitées par des acteurs malveillants :

1. Tester la résistance du réseau face aux cyberattaques (Intrusions, Vol de données)
2. Évaluer l'efficacité des mesures de sécurité actuellement en place
3. Identifier les vulnérabilités exploitables par un attaquant malveillant
4. Proposer des solutions concrètes de remédiation basées sur les normes internationales
5. Maîtriser les outils professionnels de test d'intrusion (Kali Linux)

1.4 Présentation de l'entreprise (Cas d'étude ASRdE)

Champ	Valeur
Nom du projet	ASRdE - Audit Sécurité Réseau d'Entreprise
Localisation	Faculté Polydisciplinaire de Ouarzazate
Type	Infrastructure simulée (Laboratoire virtuel VMware)
Domaine	corp.local
Encadreur	Pr. Rachid Dakir
Matière	Cybersécurité S4
Auteurs	MOHAMED AIT BELLA, BILAL SIKI

1.5 Périmètre de l'audit

Le périmètre de cet audit englobe les éléments suivants de l'infrastructure réseau :

Composant	Description	Criticité
Serveur Active Directory	Contrôleur de domaine - Gestion centralisée des accès	TRÈS HAUTE
Serveur de fichiers	Stockage des données partagées de l'entreprise	HAUTE
Firewall pfSense	Passerelle de sécurité et routage réseau	HAUTE
Équipements Switch	Infrastructure réseau commutée	MOYENNE
Stations de travail	Postes clients Windows 10/11	MOYENNE

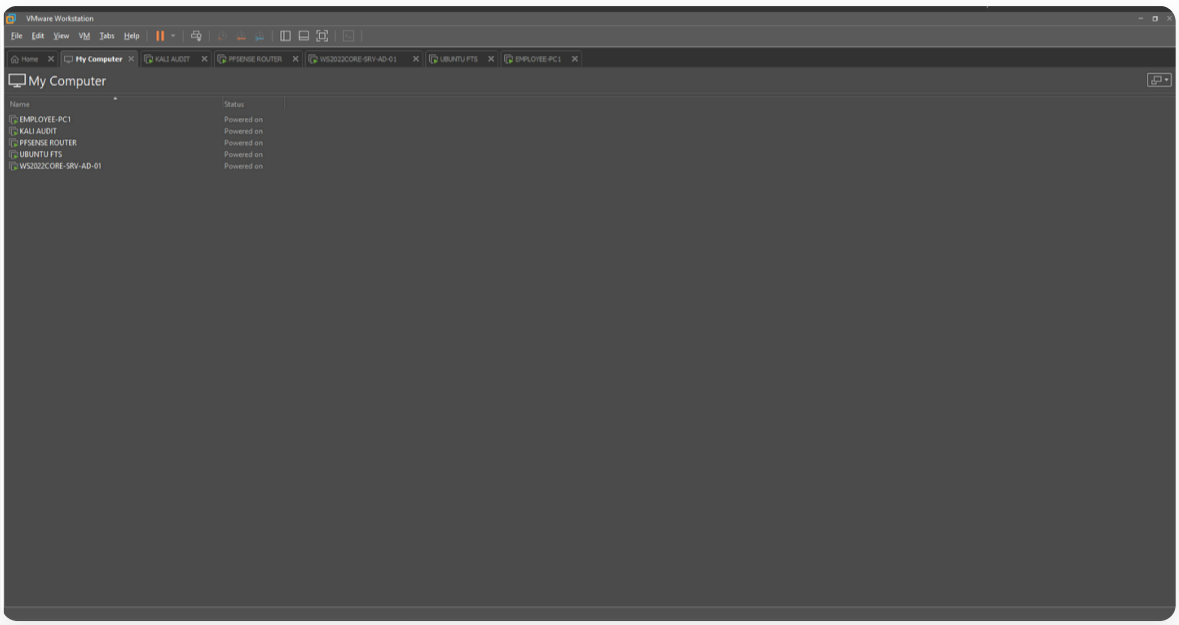

Figure 1 : Infrastructure VMware - Laboratoire virtuel d'audit

1.6 Problématique

Comment sécuriser les actifs critiques (Serveurs, Données) d'une infrastructure d'entreprise sans impacter le travail quotidien des employés ?

Cette question soulève un dilemme classique en sécurité informatique : trouver le point d'équilibre parfait entre la Sécurité et l'Accessibilité. Des mesures de sécurité trop

> restrictives peuvent entraver la productivité, tandis que des mesures trop permissives laissent l'infrastructure vulnérable aux attaques.

1.7 Analyse des risques initiaux

L'analyse des risques initiaux a identifié les principales surfaces d'attaque potentielles :

- Ports SMB (139/445) exposés sur le serveur Windows
- Services FTP avec authentification faible
- Politique de mots de passe potentiellement insuffisante
- Absence apparente de segmentation réseau
- Serveur SSH vulnérable aux exploits известные

1.8 Objectifs du projet

- Adopter le point de vue d'un attaquant (hacker éthique) pour identifier les faiblesses
- Évaluer l'efficacité des mesures de sécurité actuellement en place
- Prévenir les incidents de sécurité avant qu'ils ne se produisent
- Maîtriser les outils professionnels de test d'intrusion (Kali Linux)
- Sensibiliser aux risques liés à la faiblesse des politiques de mots de passe

1.9 Contraintes

Type	Description
Accès	Simulation en laboratoire isolé - Pas d'accès à des systèmes de production
Temps	Projet académique sur un semestre - Délai de 4 mois
Légal	Autorisation obligatoire de l'encadreur - Cadre éthique strict

1.10 Méthodologie

Notre méthodologie est basée sur les normes ISO 27001 et ISO 27005, avec une approche de test d'intrusion en 4 phases :

Phase	Nom	Objectif Principal	Outil Principal
Phase 1	Reconnaissance	Identifier les cibles vivantes et les services exposés	Nmap
Phase 2	Cartographie	Scanner et cataloguer les vulnérabilités	Nessus
Phase 3	Exploitation	Exploiter les vulnérabilités découvertes	Metasploit
Phase 4	Post-Exploitation	Évaluer l'impact et tester la robustesse des mots de passe	John the Ripper

Figure 2 : Architecture de sécurité Zero Trust - Principe de défense en profondeur

1.11 Cahier des charges

Le projet doit respecter les exigences suivantes :

- **Conformité légale :** Respect du cadre éthique avec autorisation formelle de l'encadreur
- **Environnement isolé :** Utilisation exclusive du laboratoire virtuel VMware
- **Documentation exhaustive :** Tous les résultats d'audit doivent être documentés
- **Format professionnel :** Présentation des résultats selon un format académique standard
- **Restitution :** Remise du rapport final et soutenance orale

1.12 Conclusion du chapitre

Ce chapitre a posé les fondations de l'audit de sécurité en définissant le contexte, les objectifs et la méthodologie. L'approche White Hat Hacking permet d'évaluer objectivement la posture de sécurité de l'infrastructure. Les contraintes identifiées (accès limité au laboratoire, cadre éthique strict) orientent la méthodologie vers une approche contrôlée et reproductible.

Chapitre 2 : Étude des normes et outils d'audit

2.1 Introduction

Ce chapitre présente les normes internationales et les outils professionnels utilisés pour mener à bien un audit de sécurité. La conformité aux standards reconnus garantit la rigueur et la reproductibilité de l'évaluation.

2.2 Normes et référentiels

ISO 27001

La norme ISO/IEC 27001 définit les exigences pour établir, mettre en œuvre, maintenir et améliorer un système de management de la sécurité de l'information (SMSI). Elle fournit un cadre pour la gestion des risques de sécurité.

- Gestion des risques de sécurité
- Politique de sécurité
- Organisation de la sécurité
- Gestion des actifs

ISO 27002

L'ISO 27002 complète la 27001 en fournissant des lignes directrices pour les mesures de sécurité. Elle couvre :

- Gestion des accès
- Cryptographie
- Sécurité physique
- Gestion des incidents

OWASP Top 10

L'OWASP Top 10 liste les vulnérabilités les plus critiques pour les applications web. Bien que notre audit se concentre sur l'infrastructure réseau, ces principes sont applicables à la sécurité des services exposés.

2.3 Types d'audit

Audit organisationnel

L'audit organisationnel évalue les politiques, les procédures et la gouvernance de la sécurité. Il vérifie la conformité aux normes et identifie les lacunes dans les processus.

Audit technique

L'audit technique teste directement les systèmes et l'infrastructure. Il comprend les tests de vulnérabilité, les tests d'intrusion et l'analyse de configuration.

Figure 3 : Le White Hat Hacker - Approche éthique de la sécurité offensive

2.4 Techniques d'audit

Scan de vulnérabilités

Le scan de vulnérabilités utilise des outils automatisés pour identifier les failles de sécurité connues. Nessus, OpenVAS et Qualys sont les solutions les plus utilisées.

Tests d'intrusion (Pentest)

Les tests d'intrusion simulent des attaques réelles pour exploiter les vulnérabilités découvertes. Metasploit Framework est l'outil de référence pour cette technique.

2.5 Outils d'audit

Outil	Fonction	Phase	Description
Nmap	Scan réseau	Reconnaissance	Découverte d'hôtes et énumération de services
Wireshark	Analyse trafic	Reconnaissance	Capture et analyse de paquets réseau
Nessus	Scanner vulns	Cartographie	Scanner de vulnérabilités complet
Metasploit	Exploitation	Exploitation	Framework d'exploitation et post-exploitation
John the Ripper	Password audit	Post-exploitation	Cassage de mots de passe

Commandes utilisées

```
# Scan complet des ports communs
sudo nmap -sV -O -p 21,80,139,445,3389 192.168.1.0/24

# Énumération SMB pour découvrir les utilisateurs
enum4linux -U 192.168.1.10
```

2.6 Métriques CVSS

Le CVSS (Common Vulnerability Scoring System) est un framework standardisé pour évaluer la sévérité des vulnérabilités. Le score va de 0 à 10.

Niveau	CVSS	Description	Délai de remédiation
CRITIQUE	9.0-10.0	Menace immédiate. Compromission totale.	IMMÉDIAT (< 24h)
ÉLEVÉ	7.0-8.9	Menace significative. Compromission de données.	URGENT (< 7 jours)
MOYEN	4.0-6.9	Menace modérée. Combinaison nécessaire.	PLANIFIÉ (< 30 jours)
FAIBLE	0.1-3.9	Menace minimale. Écarts par rapport aux bonnes pratiques.	À DISCRÉTION (< 90 jours)

2.7 Conclusion du chapitre

Ce chapitre a présenté le cadre normatif et les outils essentiels à l'audit de sécurité. La combinaison de normes ISO et d'outils professionnels garantit une évaluation rigoureuse et complète. Les outils présentés (Nmap, Wireshark, Nessus, Metasploit) constituent la boîte à outils du hacker éthique moderne.

Chapitre 3 : Méthodologie d'audit et collecte des données

3.1 Introduction

Ce chapitre décrit la méthodologie utilisée pour mener l'audit, depuis la préparation jusqu'à la collecte des résultats. Une approche structurée garantit la reproductibilité et la complétude de l'évaluation.

3.2 Phase de préparation

Définition du périmètre

Le périmètre a été défini en accord avec l'encadreur : réseau 192.168.1.0/24, incluant tous les serveurs et postes de travail du laboratoire virtuel.

Autorisations

Une autorisation formelle a été obtenue de l'encadreur Pr. Rachid Dakir. Seul le laboratoire isolé peut être testé. Aucune action sur des systèmes de production n'est autorisée.

3.3 Phase de reconnaissance

La phase de reconnaissance vise à découvrir les hôtes vivants sur le réseau cible et à identifier les services exposés.

Collecte d'informations

```
# Scan complet du réseau cible
sudo nmap -sV -O -p 21,80,139,445,3389 192.168.1.0/24

# Énumération SMB pour découvrir les utilisateurs
enum4linux -U 192.168.1.10
```

3.4 Scan réseau

Le scan réseau permet de découvrir tous les équipements actifs et leurs services.

Inventaire des hôtes

IP	Nom d'hôte	Rôle	OS
192.168.1.1	pfSense.corp.local	Routeur/Firewall	pfSense 2.7.2
192.168.1.10	SRV-AD-01.corp.local	Contrôleur de domaine	Windows Server 2022
192.168.1.20	fts-01.corp.local	Serveur FTP	Ubuntu Server 22.04
192.168.1.50	EMPLOYEE-PC1	Station de travail	Windows 10
192.168.1.100	fts-02.corp.local	Serveur FTP	Ubuntu Server 22.04
192.168.1.101	kali	Machine d'audit	Kali Linux 2024.1

Services découverts

Hôte	Port	Service	Version	Criticité
192.168.1.10	139, 445	SMB	Microsoft Windows netbios-ssn	CRITIQUE
192.168.1.20	21	FTP	vsftpd 3.0.5	ÉLEVÉE
192.168.1.100	21	FTP	vsftpd 3.0.5	MOYENNE

192.168.1.1	80	HTTP	nginx (pfSense WebGUI)	FAIBLE
192.168.1.10	3389	RDP	Windows Terminal Services	MOYENNE

3.5 Analyse des vulnérabilités

Le scanner Nessus a identifié plusieurs vulnérabilités classées par sévérité :

Plugin ID	Nom	Sévérité	CVSS	Hôte
CVE-2024-6387	OpenSSH < 9.8 RCE (regreSSHion)	Élevée	8.1	192.168.1.20
CVE-2023-48795	OpenSSH < 9.6 MitM	Moyenne	6.8	192.168.1.20
CVE-2023-46454	OpenSSH < 9.5 DoS	Moyenne	5.9	192.168.1.20

3.6 Tests d'intrusion

L'exploitation contrôlée avec Metasploit a permis de prouver la réalité des vulnérabilités découvertes.

```
# Module de force brute SMB
use auxiliary/scanner/smb/smb_login
set RHOSTS 192.168.1.10
set SMBUser admin-audit
set PASS_FILE /home/kali/wordlists/rockyou.txt
run
```

RÉSULTAT : L'attaque par force brute SMB a permis de découvrir le mot de passe du compte 'admin-audit' : 'P@ssword2026!'. Ce mot de passe était présent dans un dictionnaire restreint de mots de passe courants.

3.7 Analyse du trafic

Wireshark a été utilisé pour analyser le trafic réseau et identifier les communications non chiffrées ou suspectes.

3.8 Collecte des résultats

Tous les résultats ont été documentés : logs Nmap, rapports Nessus, sessions Metasploit et résultats John the Ripper.

```
# Résultats John the Ripper - Cassage de hachages NT
$ sudo john --format=NT --wordlist=Reduced_Wordlist.txt Extracted_hash
Using default input encoding: UTF-8
Loaded 1 password hash (NT [MD4 512/512 AVX512BW 16x3])
Password123! (Employee1)
1g 0:00:00:00 DONE (2026-04-04 16:02) 33.33g/s 6733p/s 6733c/s
```

3.9 Conclusion du chapitre

Ce chapitre a détaillé la méthodologie de collecte des données avec une approche systématique incluant Les données collectées comprennent les résultats de scan Nmap, les rapports Nessus, les sessions Metasploit et les hashes cassés avec John the Ripper. L'ensemble de ces données forme la base de l'analyse qui sera présentée dans le chapitre suivant pour identifier précisément les vulnérabilités exploitables et évaluer leur impact sur la sécurité globale du réseau ASRdE.

Chapitre 4 : Analyse des résultats et identification des failles

4.1 Introduction

Ce chapitre présente l'analyse détaillée des vulnérabilités découvertes, leur classification par niveau de criticité et leur impact potentiel sur l'entreprise.

4.2 Cartographie du réseau

La cartographie du réseau a été établie à partir des résultats du scan. Elle identifie les composants critiques et leurs interconnexions au sein du réseau 192.168.1.0/24.

4.3 Identification des vulnérabilités

Vulnérabilités Critiques

> **NIVEAU CRITIQUE : CVSS 9.8**
>
> **Identifiants SMB faibles et compromission du contrôleur de domaine.**
>
> L'attaque par force brute a permis d'obtenir les accès administrateur. PsExec a ensuite été utilisé pour obtenir une session Meterpreter avec les droits NT AUTHORITY\SYSTEM.

Vulnérabilités Élevées

OpenSSH obsolète (antérieur à 9.8) sur le serveur Ubuntu 192.168.1.20 permet potentiellement l'exécution de code à distance (RCE) avec un score CVSS de 8.1.

Vulnérabilités Moyennes et Faibles

Plusieurs vulnérabilités de niveau moyen ont été identifiées, notamment les risques MitM sur OpenSSH et les services RDP exposés.

4.4 Analyse des risques

Vulnérabilité	Impact	Probabilité	Score CVSS
SMB weak password	Contrôle total du domaine AD	Très haute	9.8
PsExec exploitation	Extraction des hachages	Très haute	9.8
OpenSSH RCE	Exécution de code sur serveur Linux	Haute	8.1
AD weak passwords	Compromission des comptes utilisateurs	Haute	7.5

4.5 Exemples de failles détaillées

Vulnérabilité #1 : Identifiants Administratifs SMB Faibles

Niveau : CRITIQUE | **CVSS :** 9.8 | **Cible :** 192.168.1.10

Une attaque par force brute sur SMB (ports 139/445) a permis de découvrir le mot de passe 'P@ssword2026!' du compte 'admin-audit'. Cette chaîne est présente dans les dictionnaires de mots de passe courants.

```
[*] 192.168.1.10:445 - Starting SMB login bruteforce
[-] 192.168.1.10:445 - Failed: '.\admin-audit:123456'
[-] 192.168.1.10:445 - Failed: '.\admin-audit:password'
[+] 192.168.1.10:445 - Success: '.\admin-audit:P@ssword2026!'
```

Impact métier

L'accès à ce compte permet à un attaquant de s'authentifier sur le serveur Windows avec des privilèges élevés. Cette compromission ouvre la voie à une escalade de privilèges et une compromission totale du système cible.

Vulnérabilité #2 : Exploitation PsExec et Hashdump

Niveau : CRITIQUE | **CVSS :** 9.8 | **Cible :** 192.168.1.10

Suite à l'obtention des identifiants privilégiés, PsExec a été utilisé pour obtenir une session Meterpreter SYSTEM. L'extraction des hachages SAM/NTDS a ensuite été réalisée.

```
meterpreter > getsystem
[+] Ticket: 'NT AUTHORITY\SYSTEM' already established

meterpreter > hashdump
Administrator: 500: aad3b435b51404eeaad3b435b51404ee:fbcfd43dfda21ef615975ab1da
krbtgt: 502: aad3b435b51404eeaad3b435b51404ee:fd35e27d3f95078c90725ef0e25ef4db
Employee1: 1106: aad3b435b51404eeaad3b435b51404ee:2b576acbe6bcfda7294d6bd18041b
```

> **IMPACT MÉTIER :** Cette compromission représente une APT (Advanced Persistent Threat) simulée réussie. L'attaquant détient désormais le contrôle absolu sur le serveur Windows compromis, accès à tous les utilisateurs du domaine Active Directory, et la capacité de créer des portes dérobées persistantes.

4.6 Tableaux de priorisation

Les actions de remédiation ont été priorisées selon le score CVSS et l'impact métier.

Priorité	Action	Délai
1	Changer mot de passe admin-audit et Administrator	IMMÉDIAT
2	Désactiver SMBv1 sur tous les serveurs	24h
3	Mettre à jour OpenSSH vers version 9.8+	7 jours
4	Réinitialiser tous les mots de passe AD	7 jours
5	Activer MFA sur tous les accès privilégiés	30 jours

4.7 Conclusion du chapitre

Ce chapitre a présenté l'analyse approfondie des vulnérabilités découvertes lors de l'audit. Les résultats révèlent des failles critiques, notamment les identifiants SMB faibles permettant un accès non autorisé au contrôleur de domaine et l'exploitation de PsExec pour l'extraction des hachages. La classification par score CVSS a permis de prioriser les actions de remédiation. Le chapitre suivant détaillera les recommandations spécifiques pour corriger ces vulnérabilités et renforcer la posture de sécurité globale du réseau ASRdE.

Chapitre 5 : Recommandations et plan d'amélioration

5.1 Introduction

Ce chapitre présente les recommandations de remédiation et le plan d'amélioration continue de la posture de sécurité. Les solutions sont classées par horizon temporel et par axe d'action.

5.2 Plan de remédiation

Correction des failles critiques

- Changer immédiatement les mots de passe du compte 'admin-audit' et 'Administrator' avec des chaînes aléatoires d'au moins 16 caractères
- Réinitialiser les mots de passe de tous les utilisateurs du domaine
- Configurer le verrouillage des comptes (Account Lockout Policy) après 5 tentatives de connexion échouées
- Désactiver ou renommer le compte 'admin' par défaut

5.3 Renforcement de la sécurité

Pare-feu (Firewall)

Renforcer les règles du firewall pfSense : restriction des accès par IP source, blocage par défaut des ports non essentiels, activation de l'inspection Stateful.

IDS/IPS

Déployer un système de détection d'intrusion (IDS) pour identifier les comportements suspects comme l'énumération SMB ou l'utilisation de PsExec.

5.4 Politique de sécurité

Gestion des accès

Implémenter le principe du moindre privilège : les utilisateurs n'ont accès qu'aux ressources strictement nécessaires à leur fonction.

Paramètre	Valeur Recommandée
Longueur minimale	12 caractères (14 pour admin)
Complexité requise	Activé (majuscules, minuscules, chiffres, symboles)
Historique de mot de passe	12 mots de passe remember
Expiration	90 jours (45 jours pour admin)
Verrouillage après	5 tentatives échouées
Durée du lockout	30 minutes

5.5 Segmentation VLAN

La segmentation réseau par VLANs limite la propagation d'une attaque et contrôle les flux de trafic.

VLAN ID	Nom	Plage IP	Description
10	VLAN Direction	192.168.10.0/24	Direction et cadres supérieurs
20	VLAN RH	192.168.20.0/24	Ressources humaines et paie
30	VLAN IT	192.168.30.0/24	Équipe informatique
40	VLAN Finance	192.168.40.0/24	Comptabilité et finances

50	VLAN Production	192.168.50.0/24	Serveurs d'applications
60	VLAN Databases	192.168.60.0/24	Bases de données critiques
99	VLAN Invités	192.168.99.0/24	Visiteurs et externes

5.6 Déploiement MFA

- Utiliser Microsoft Entra ID (Azure AD) pour le SSO et le MFA centralisé
- Déployer l'application Microsoft Authenticator sur les appareils mobiles des utilisateurs
- Activer le MFA pour tous les accès à Microsoft 365, VPN, et administration Azure
- Préférer les méthodes d'authentification forte (clés de sécurité FIDO2)

5.7 Plan d'action priorisé

Horizon	Actions	Délai
Court terme	Changement mots de passe, mise à jour OpenSSH, activation lockout	< 7 jours
Moyen terme	Déploiement MFA, implémentation VLAN, configuration GPO	< 30 jours
Long terme	Déploiement SOC/SIEM, programme sensibilisation, audits réguliers	< 6 mois

5.8 Suivi et amélioration continue

La sécurité est un processus continu. Un audit annuel au minimum est recommandé, avec des scans de vulnérabilités trimestriels. Le déploiement d'un SOC (Security Operations Center) permettra une surveillance 24/7.

Chapitre 6 : Conclusion générale et perspectives

6.1 Bilan global

Cet audit de sécurité complet a permis d'identifier et d'exploiter plusieurs vulnérabilités critiques au sein de l'infrastructure réseau simulée. Les résultats obtenus démontrent sans ambiguïté que la posture de sécurité actuelle est insuffisante face aux menaces modernes.

> **RÉSULTAT CLÉ :** La compromission du contrôleur de domaine Active Directory en moins de 30 minutes illustre la gravité des failles identifiées et l'urgence d'une remédiation immédiate.

La triade des compromissions réussies (SMB weak password → PsExec → Hashdump) forme une chaîne d'attaque classique mais redoutablement efficace.

6.2 Résultats de l'audit

- La politique de mots de passe en place est inefficace et permet une compromission triviale
- Le protocole SMB mal configuré constitue une porte d'entrée majeure pour les attaquants
- L'absence de détection permet à l'attaquant d'opérer sans être inquiété
- Le manque de segmentation facilite le mouvement latéral vers tous les systèmes

6.3 Apports du projet

Ce projet a permis de maîtriser les outils suivants de la distribution Kali Linux :

- **Nmap** pour la reconnaissance et l'énumération réseau
- **enum4linux** pour l'extraction d'informations depuis les partages SMB
- **Nessus** pour le scan de vulnérabilités automatisé

- **Metasploit Framework** pour l'exploitation et le mouvement latéral
- **John the Ripper** pour le cassage de mots de passe

6.4 Perspectives

Les perspectives d'amélioration incluent :

- **Déploiement SOC** (Security Operations Center) pour la surveillance continue
- **Implémentation SIEM** (Security Information and Event Management) pour la corrélation des événements
- **Programme de sensibilisation** régulier pour tous les employés
- **Audits réguliers** (au minimum annuels) de la posture de sécurité
- **Déploiement EDR** (Endpoint Detection and Response) pour détecter les comportements malveillants

> **CONCLUSION :** En appliquant les mesures de Hardening préconisées — notamment la segmentation par VLANs, le déploiement de politiques GPO strictes et l'activation du MFA — l'organisation pourra atteindre l'équilibre vital entre une sécurité robuste (Intégrité/Confidentialité) et la fluidité opérationnelle nécessaire aux employés (Disponibilité).

Annexes

Annexe A : Logs de reconnaissance Nmap

```
$ sudo nmap -sV -O -p 21,80,139,445,3389 192.168.1.0/24
Starting Nmap 7.95 (https://nmap.org) at 2026-04-04 14:55 EDT
Nmap scan report for 192.168.1.10
Host is up (0.0027s latency).
PORT STATE SERVICE VERSION
139/tcp open netbios-ssn Microsoft Windows netbios-ssn
445/tcp open microsoft-ds?
3389/tcp closed ms-wbt-server
MAC Address: 00:0C:29:FA:D2:9A (VMware)
Running: Microsoft Windows 2016|2019
Nmap scan report for 192.168.1.20
Host is up (0.0024s latency).
PORT STATE SERVICE VERSION
21/tcp open ftp vsftpd 3.0.5
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
Nmap done: 256 IP addresses (6 hosts up) scanned in 15.94 seconds
```

Annexe B : Tableau récapitulatif des vulnérabilités

ID	Vulnérabilité	CVSS	Sévérité	Statut
VULN-001	SMB Weak Password	9.8	CRITIQUE	Exploité
VULN-002	PsExec RCE	9.8	CRITIQUE	Exploité
VULN-003	OpenSSH RCE (CVE-2024-6387)	8.1	ÉLEVÉE	Identifié
VULN-004	AD Weak Passwords	7.5	ÉLEVÉE	Identifié
VULN-005	OpenSSH MitM	6.8	MOYENNE	Identifié

Annexe C : Script d'audit utilisé

```
#!/bin/bash
# Script de scan réseau automatisé

TARGET_NETWORK="192.168.1.0/24"
OUTPUT_FILE="scan_results_$(date +%Y%m%d).txt"

# Scan des ports communs
sudo nmap -sV -O -p 21,80,139,445,3389 $TARGET_NETWORK > $OUTPUT_FILE

# Énumération SMB
enum4linux -a 192.168.1.10 >> $OUTPUT_FILE

echo "Scan terminé. Résultats dans $OUTPUT_FILE"
```

Bibliographie

[1] ISO/IEC 27001:2022 - Information security management systems - Requirements

[2] ISO/IEC 27002:2022 - Information security controls

[3] NIST SP 800-53 - Security and Privacy Controls for Information Systems

[4] CVSS v3.1 Specification Document - FIRST.org

[5] OWASP Top 10 (2021) - Web Application Security Risks

[6] Metasploit Framework Documentation - Rapid7

[7] Nessus Professional - Vulnerability Scanner Documentation

[8] CIS Controls v8 - Center for Internet Security

[9] NIST Cybersecurity Framework (CSF)

Rapport d'Audit de Sécurité Réseau ASRdE

MOHAMED AIT BELLA, BILAL SIKI — Avril 2026

Faculté Polydisciplinaire de Ouarzazate — Cybersécurité S4

Encadreur : Pr. Rachid Dakir